

计算机网络 (第 6/7/8 版)

第 7 章 网络安全

第 7 章 网络安全



7.1 网络安全问题概述

7.1.1 计算机网络面临的安全性威胁

7.1.2 计算机网络安全的内容

7.1.3 一般的数据加密模型

7.2 两类密码体制

7.2.1 对称密钥密码体制

7.2.2 公钥密码体制

7.3 数字签名

7.4 鉴别

7.4.1 报文鉴别

7.4.2 实体鉴别

第 7 章 网络安全 (续)



7.5 密钥分配

7.5.1 对称密钥的分配

7.5.2 公钥的分配

7.6 因特网使用的安全协议

7.6.1 网络层安全协议

7.6.2 运输层安全协议

7.6.3 应用层的安全协议破

7.7 系统安全：防火墙与入侵检测

7.7.1 防火墙

7.7.2 入侵检测系统

7.8 计算机病毒



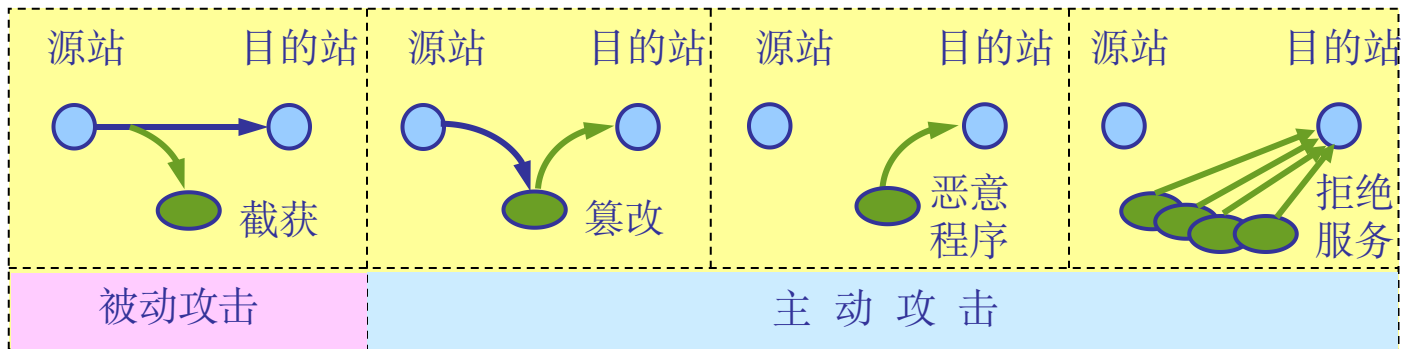
7.1 网络安全问题概述

7.1.1 计算机网络面临的安全性威胁

计算机网络上的通信面临以下两大类威胁：

1. 被动攻击。主要是截获，即从网络上窃听他人的通信内容。
2. 主动攻击，主要有：
 - 篡改——故意篡改网络上传送的报文。
 - 恶意程序——包括计算机病毒、计算机蠕虫、特洛伊木马和逻辑炸弹等。
 - 拒绝服务——包括分布式拒绝服务。

对网络的被动攻击和主动攻击

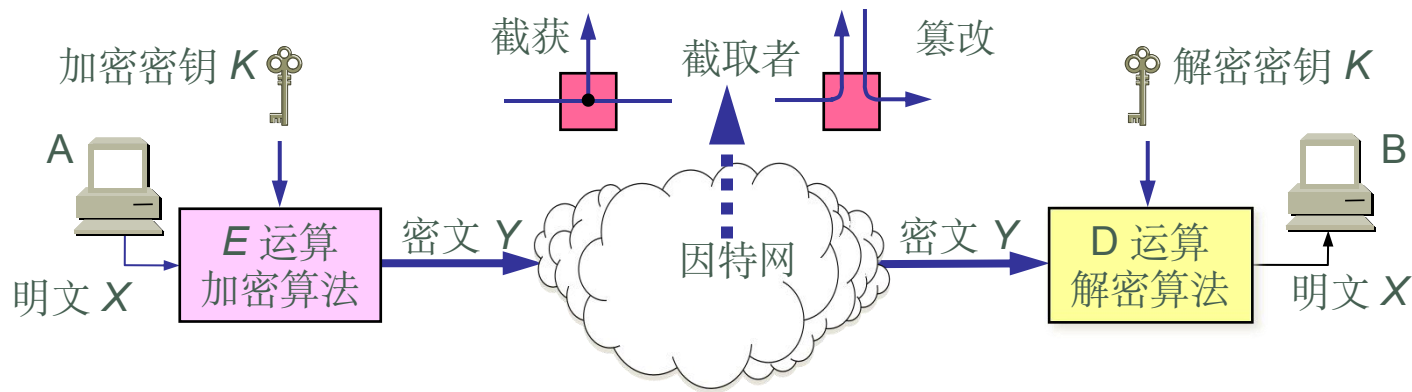


7.1.2 计算机网络安全的内容



- 保密性
- 安全协议的设计
- 访问控制

7.1.3 一般的数据加密模型

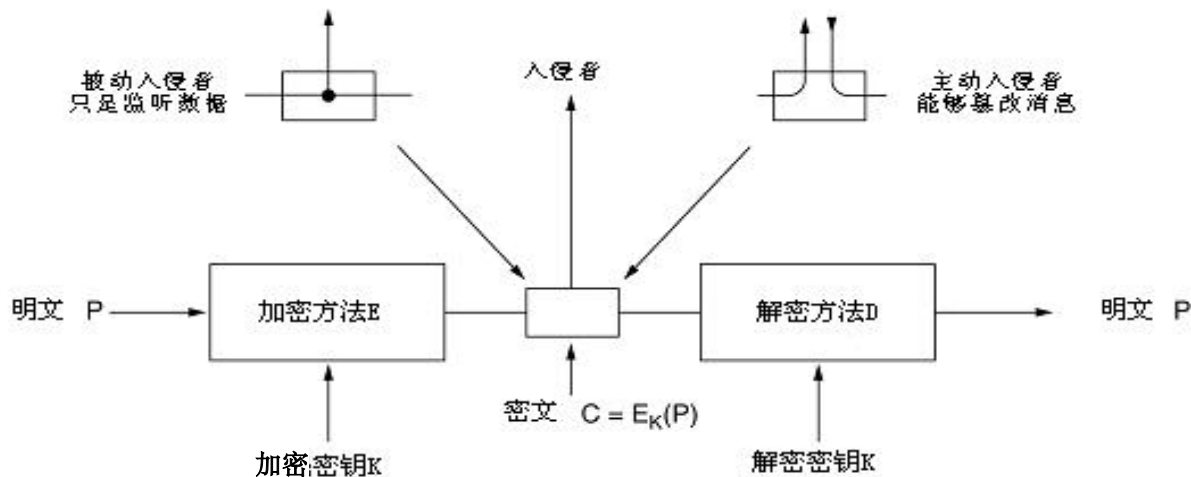


一些重要概念



- 密码编码学(cryptography)是密码体制的设计学，而密码分析学(cryptanalysis)则是在未知密钥的情况下从密文推演出明文或密钥的技术。密码编码学与密码分析学合起来即为密码学(cryptology)。
- 如果不论截取者获得了多少密文，但在密文中都没有足够的信息来唯一地确定出对应的明文，则这一密码体制称为无条件安全的，或称为理论上是不可破的。
- 如果密码体制中的密码不能被可使用的计算资源破译，则这一密码体制称为在计算上是安全的。

密码学简介 (1)



- 待加密的消息为**明文** (plaintext)，它经过一个以**密钥** (key) 为参数的函数变换，这个过程称为**加密**，输出的结果称为**密文** (ciphertext)
- 设计加密和解密方法的艺术称为**密码编码学**，破解密码的艺术称为**密码分析学**，两者统称为**密码学**

密码学简介 (2)



- 符号标记
 - 明文 P ; 密钥 K ; 密文 C
- 加密过程
 - $C = E_k(P)$
- 解密过程
 - $P = D_k(C)$
- Kerckhoff原则: “让密码分析者知道加解密算法, 把所有的秘密信息全放在密钥中”
- 密钥长度越长, 破解难度越大!

密码学简介 (3)



- 密码分析方法

- 只有密文攻击

- ◆ 密码分析者只得到了一定量的密文，但是没有对应的明文

- 已知明文攻击

- ◆ 密码分析者有一些相匹配的密文和明文

- 选择明文攻击

- ◆ 密码分析者能够加密某些他自己选择的明文

- 密码必须能抵抗上述三种攻击!

置换密码 (1)



- 置换密码 (substitution cipher)

- 每个字母或者每一组字母被另一个字母或者另一组字母取代
- 不改变明文字母的顺序，但是把字母伪装起来

- 凯撒密码 (Caesar cipher)

- 每一个字母被位于其后的第三个字母代替
 - ◆ 一个例子: `attack -> dwwdfn`
- 一个通用方案是允许字母表被移动 k 个字母而不是3个，此时 k 相当于字母表循环移动算法的密钥
- 优点：简单；
- 缺点：极其容易破译

置换密码 (2)



- 单字母表置换

- 让明文中的每一个字符都映射到其他一个字符上

- 例如 `abcdefghijklmnopqrstuvwxyz`

`QWERTYUIOPASDFGHJKLZXCVBNM`

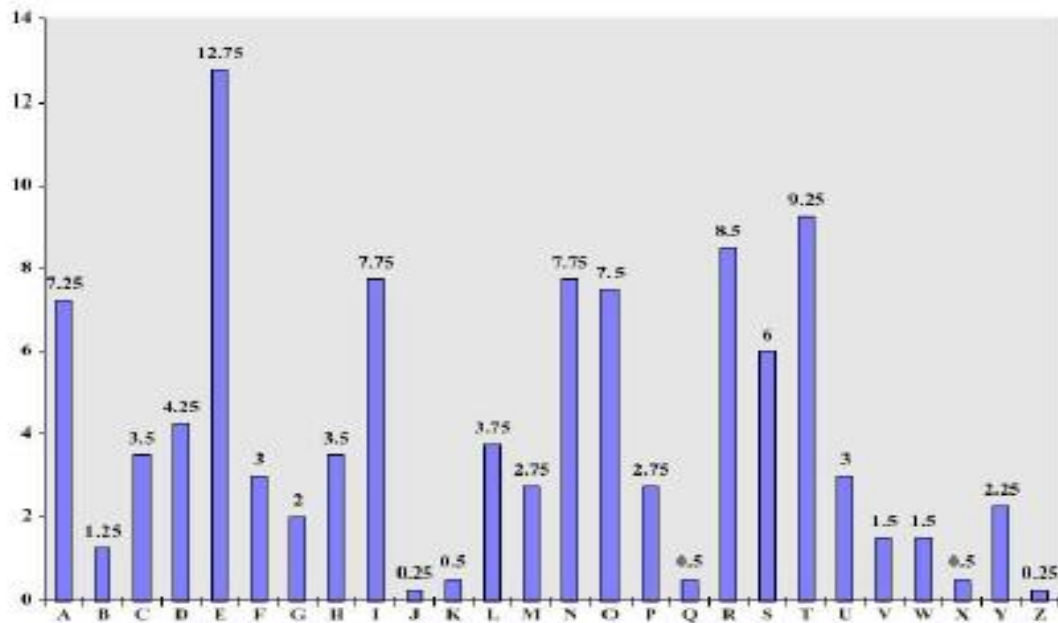
则 `attack` -> `QZZQEA`

- 密钥共有 $26! \approx 4 \times 10^{26}$ 种可能，穷举攻击计算上不可行

置换密码 (3)



- 利用自然语言的统计特性很容易破解密码。例如英文中e, t, o, a, n, i是最常出现的字母



转置密码 (1)



● 转置密码 (transposition cipher)

- 重新对字母进行排序，但是不伪装明文
- 下图给出了一种常见的转置密码：柱形转置

- ◆ MEGABUCK是密钥，作用是对矩阵列进行编号，例中第一列为A代表的那一列，以此类推
- ◆ 明文按水平方向的行依次填充矩阵
- ◆ 密文按列读出，列次序如密钥所规定

<u>M</u>	<u>E</u>	<u>G</u>	<u>A</u>	<u>B</u>	<u>U</u>	<u>C</u>	<u>K</u>
<u>7</u>	<u>4</u>	<u>5</u>	<u>1</u>	<u>2</u>	<u>8</u>	<u>3</u>	<u>6</u>
p	l	e	a	s	e	t	r
a	n	s	f	e	r	o	n
e	m	i	l	l	i	o	n
d	o	l	l	a	r	s	t
o	m	y	s	w	i	s	s
b	a	n	k	a	c	c	o
u	n	t	s	i	x	t	w
o	t	w	o	a	b	c	d

Plaintext

pleasetransferonemilliondollarsto
myswissbankaccountsixtwo

Ciphertext

AFLLSKSOSELAWAIATOOSSCTCLNMOMANT
ESILYNTWRNNTSOWDPAEDOBUEIRICXB

转置密码 (2)



● 转置密码破译方法

- 观察英文常用字母出现的频率是否与明文的常规频率吻合，是的话则可以确定是转置密码
- 根据特定的环境信息猜测一个可能的单词或者短语，观察单词中两字母组合的规律来确定列数
- 当列数较小的时候，共有 $K(K-1)$ 种可能的列对，对每一个列对进行检查看它的两字母组合的频率是否与英文两字母组合频率相匹配，依此逐步确认列的顺序。

一次一密 (1)



- 一次一密 (one-time pad)

- 选择一个随机的位串作为密钥，将明文转变成一个位串，然后逐位计算两个串的异或值作为密文
- 信息论表明，在没有密钥的情况下密文无法破解
- 缺点
 - ◆ 密钥量大，无法记忆，必须携带书面副本
 - ◆ 对于丢失字符和插入字符敏感，发送方和接收方必须保持同步

一次一密 (2)



● 一次一密示例

➤ 明文: I love you.

➤ 密钥是Pad1, 若选择Pad2用来解密, 得到明文结果Elvis lives, 似是而非

Message 1: 1001001 0100000 1101100 1101111 1110110 1100101 0100000 1111001 1101111 1110101 0101110

Pad 1: 1010010 1001011 1110010 1010101 1010010 1100011 0001011 0101010 1010111 1100110 0101011

Ciphertext: 0011011 1101011 0011110 0111010 0100100 0000110 0101011 1010011 0111000 0010011 0000101

Pad 2: 1011110 0000111 1101000 1010011 1010111 0100110 1000111 0111010 1001110 1110110 1110110

Plaintext 2: 1000101 1101100 1110110 1101001 1110011 0100000 1101100 1101001 1110110 1100101 1110011

一次一密 (3)



- 量子密码学
 - BB84协议

两条密码学原则 (1)



- 原则1：被加密的消息必须包含一定的冗余度

- 解密一条消息之后，接收者必须能够通过简单的检查手段或者计算来判断消息是否有效
- 冗余信息对理解消息是不必要的，但是能够阻止主动入侵者发送垃圾信息，并欺骗接收者解密垃圾信息并在所谓的“明文”上执行相应的处理
- 缺憾是冗余信息使被动入侵者也更加容易破解系统

两条密码学原则 (2)



- 原则2：需要采取某种方法来对抗重放攻击

- 确保接收到的消息能被验证是新鲜的，是最近被发出来的，而不是重放的
- 一种措施是在每条消息中包括一个时间戳，以便表明消息的有效时间段
- 其他措施

7.2 两类密码体制



7.2.1 对称密钥密码体制

- 所谓常规密钥密码体制，即加密密钥与解密密钥是相同的密码体制。
- 这种加密系统又称为对称密钥系统。

数据加密标准 DES



- 数据加密标准 DES 属于常规密钥密码体制，是一种分组密码。
- 在加密前，先对整个明文进行分组。每一个组长为 64 位。
- 然后对每一个 64 位 二进制数据进行加密处理，产生一组 64 位密文数据。
- 最后将各组密文串接起来，即得出整个的密文。
- 使用的密钥为 64 位（实际密钥长度为 56 位，有 8 位用于奇偶校验）。

1 概述 (1)



- 现代密码学仍然使用置换和转置的思想，但是加密算法尽可能地错综复杂
- 对称密钥算法 (symmetric-key algorithm)
 - 使用同样的密钥完成加密和解密操作
- 块密码 (block cipher)
 - 接受一个 n 位的明文块作为输入，利用密钥变换成 n 位的密文块

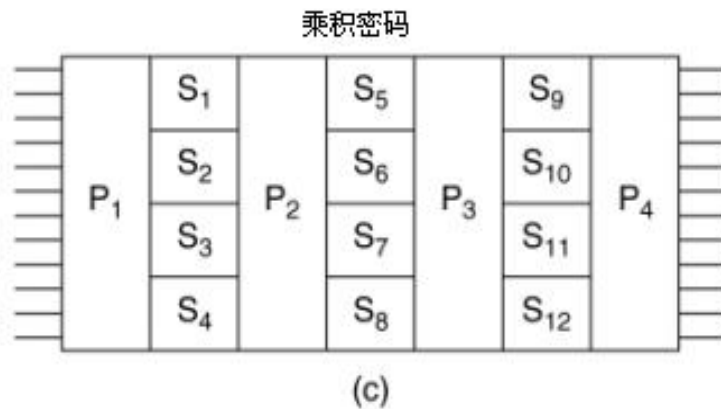
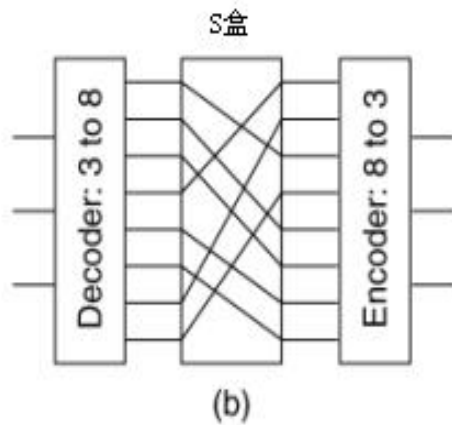
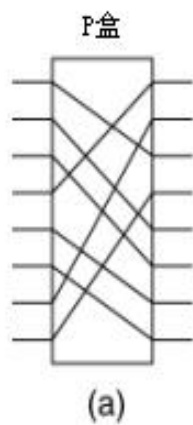
1 概述 (2)



- 乘积密码 (product cipher)

- P盒完成转置, S盒完成置换

- 一系列S盒和P盒叠加起来构成乘积密码, 现代加密算法大多是乘积密码



2 数据加密标准DES (1)



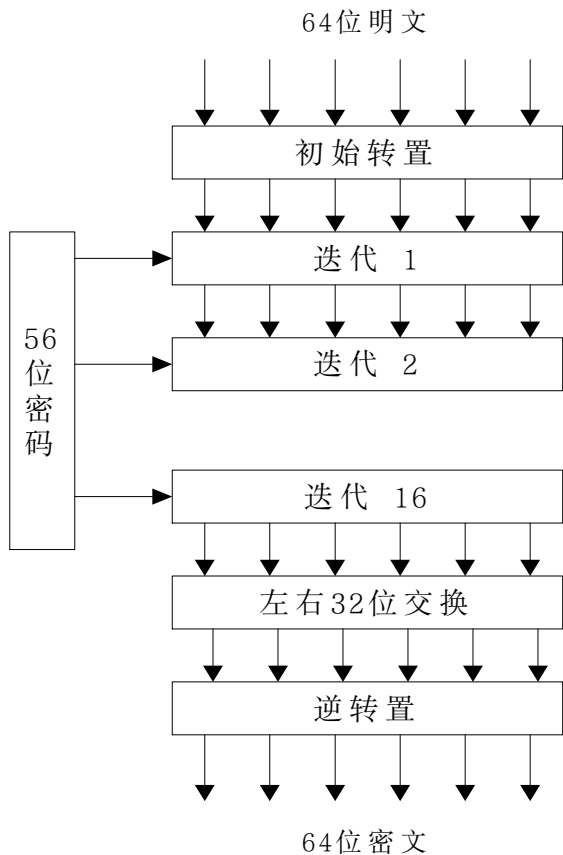
- 1977年，美国政府采纳了IBM开发的一个乘积密码作为无密级信息的官方加密标准，这个算法称为DES (Data Encryption Standard, 数据加密标准)
- 关于DES的争议不断。美国国家安全局NSA使IBM把密钥从128位降低到56位，并且把DES的设计过程保密起来，人们怀疑DES算法隐藏了后门，NSA很容易破解。
- 最初的DES已经不适用，一个改进形式仍然非常有用

2 数据加密标准DES (2)



● DES工作流程

- 明文按**64位**数据块的单元被加密，生成**64位**密文；密钥**56位**
- 共**19**个步骤。第一步是一个与密钥无关的转置操作，直接作用在明文上；最后一步是这次转置的逆操作；倒数第二步是交换左**32**位和右**32**位；其他**16**步在功能上完全相同，但是使用原始密钥的不同函数作为参数
- 用同样的密钥可以完成解密，但是解密步骤与加密步骤相反

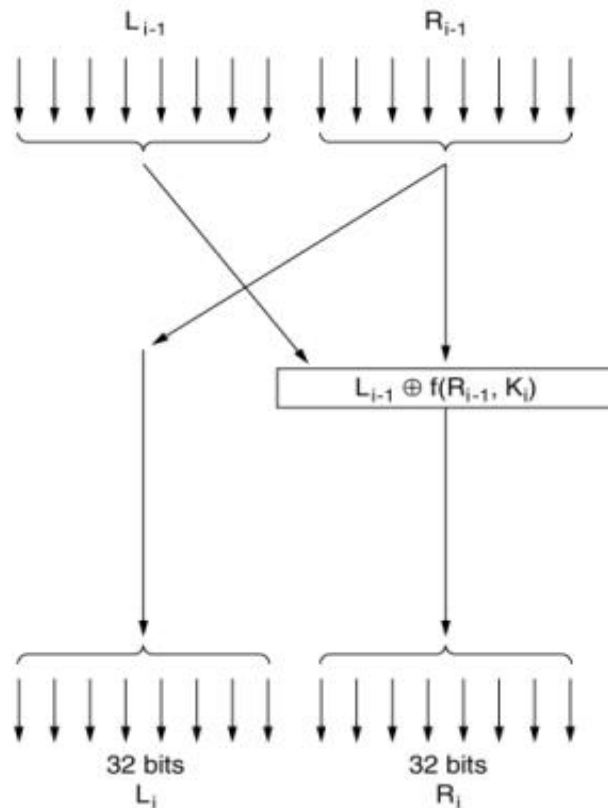


2 数据加密标准DES (3)



● 一次迭代过程 (一轮)

- 接受两个32位输入(L_{i-1} , R_{i-1}), 产生两个32位输出(L_i , R_i)
- 左边的输出 L_i 等于右边的输入 R_{i-1}
- 右边的输出是左边输入 L_{i-1} 与一个函数值 $f(R_{i-1}, K_i)$ 逐位异或的结果, 该函数的输入参数是右边的输入 R_{i-1} 和本轮的密钥 K_i

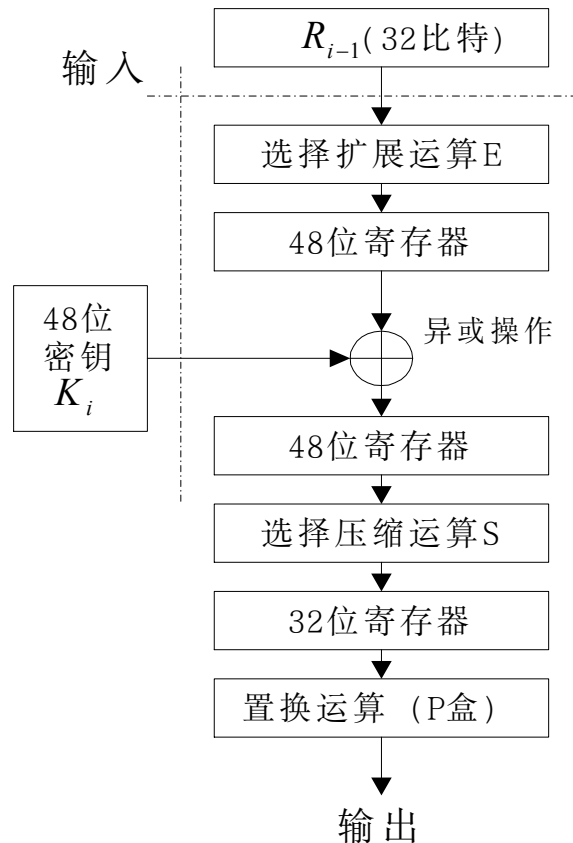


2 数据加密标准DES (4)



● F函数

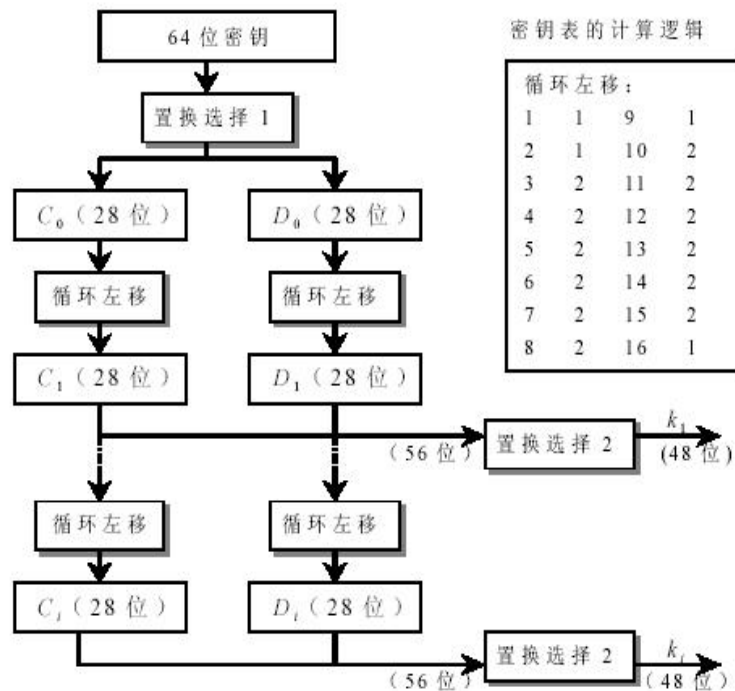
- 第一步：根据一个固定的转置和复制规则，将32位的 R_{i-1} 扩展成一个48位的数字 E
- 第二步： E 和 K_i 被异或在一起
- 第三步：异或结果被分成8个6位组，每个6位组被输入到不同的S盒中。每个S盒将6位输入映射到一个4位（压缩）输出
- 第四步：8个4位通过一个P盒，得到32位输出



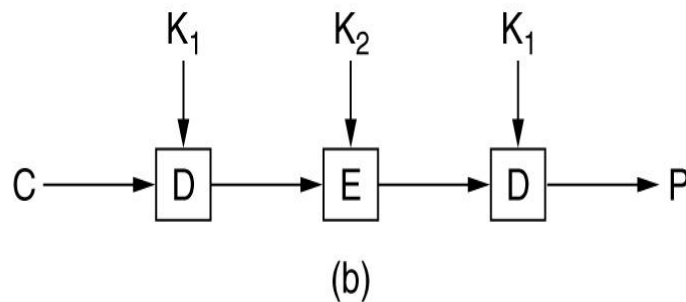
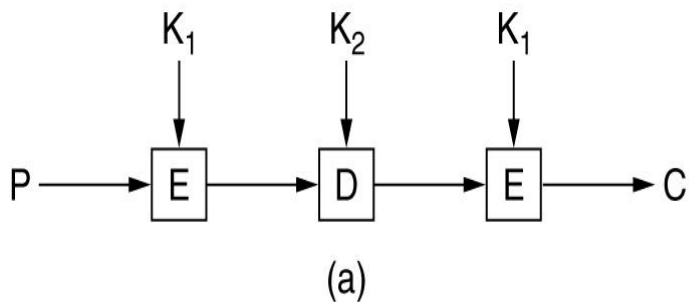
2 数据加密标准DES (5)

● 轮密钥的产生

- 首先从64位密钥K中提取出56位，并执行转置操作
- 每一次迭代之前，密钥被分成两个28位单元，每个单元循环左移位，左移位数取决于当前的迭代号
- 移位之后再执行另外一个转置操作，即得到 K_i



2 数据加密标准DES (6)



● 三重DES

- 1979年初，IBM意识到DES的密钥长度太短，于是设计了三重DES来增加密钥长度
- 共三步：第一步按照常规的方式用密钥K1执行DES加密；在第二步中，DES以解密方式运行，并使用K2作为密钥；第三步再次用K1执行DES加密
- EDE（加密-解密-加密）模式是为了与现有的DES系统保持兼容性，并且112位密钥已经足够长了

DES 的保密性



- DES 的保密性仅取决于对密钥的保密，而算法是公开的。尽管人们在破译 DES 方面取得了许多进展，但至今仍未能找到比穷举搜索密钥更有效的方法。
- DES 是世界上第一个公认的实用密码算法标准，它对密码学的发展做出了重大贡献。
- 目前较为严重的问题是 DES 的密钥的长度。
- 现在已经设计出来搜索 DES 密钥的专用芯片。

7.2.2 公钥密码体制



- 公钥密码体制使用不同的加密密钥与解密密钥，是一种“由已知加密密钥推导出解密密钥在计算上是不可行的”密码体制。
- 公钥密码体制的产生主要是因为两个方面的原因，一是由于常规密钥密码体制的密钥分配问题，另一是由于对数字签名的需求。
- 现有最著名的公钥密码体制是RSA 体制，它基于数论中大数分解问题的体制，由美国三位科学家 Rivest, Shamir 和 Adleman 于 1976 年提出并在 1978 年正式发表的。

公开密钥算法 (1)



- 在对称密钥系统中，分发密钥往往是最薄弱的环节
- 1976年，Stanford的Diffie和Hellman提出了一种全新的密钥系统
 - 加密密钥和解密密钥不同，从加密密钥不能轻易地推出解密密钥
 - 加密算法E和解密算法D必须满足三个要求：
 - ◆ $D(E(P)) = P$
 - ◆ 从E推出D极其困难
 - ◆ 用选择明文攻击不可能破解E
 - 具备了上述条件之后，加密密钥和加密算法都可以被公开
- 该系统命名为公开密钥密码系统 (public-key cryptography)

公开密钥算法 (2)



● 若干术语

- 公开密钥密码系统要求每个用户拥有两个密钥，一个是公开密钥（公钥），另一个是私有密钥（私钥）
- 其他人给某个用户发送消息的时候，用该用户的公钥加密
- 用户解密收到的消息的时候，使用私钥解密

公开密钥算法 (3)



- RSA算法由MIT的Rivest、Shamir、Adleman提出
- 预计算
 - 选择两个大的素数 p 和 q (通常1024位)
 - 计算 $n = p * q$ 和 $z = (p - 1)*(q - 1)$
 - 选择一个与 z 互素的数, 称为 d
 - 找到 e , 使其满足 $e * d = 1 \bmod z$
- 公钥对是 (e, n) , 私钥对是 (d, n)
- 加密
 - 加密消息 P , 只需要计算 $C = P^e \bmod n$ 即可
- 解密
 - 解密密文 C , 只需要计算 $P = C^d \bmod n$ 即可
- 明文分块
 - 将明文化分成 k 位的块, k 是满足 $2^k < n$ 的最大整数

公开密钥算法 (4)



- 加密和解密的运算可以对调，即

$$E_{PK_B}(D_{SK_B}(X)) = D_{SK_B}(E_{PK_B}(X)) = X$$

- 在计算机上可容易地产生成对的 PK 和 SK 。
- 从已知的 PK 实际上不可能推导出 SK ，即从 PK 到 SK 是“**计算上不可能**”。
- 加密和解密算法都是公开的。
- RSA算法的安全性建立在大数分解的难度基础上，如果能够分解大数 n ，则算法自动破解。但是数学家探索了大数分解300年也进展不大
- 算法的缺点是速度太慢，一般用来分发密钥，而不直接用来加密数据

RSA例子



- 取 $p = 3, q = 11$
- 计算 $n = 33 \quad z = 20$
- 取 $d = 7$, 计算出 $e = 3$
- $C = P^3 \pmod{33}; P = C^7 \pmod{33}$

明文 (P)		密文 (C)			解密之后	
符号	数值	P^3	$P^3 \pmod{33}$	C^7	$C^7 \pmod{33}$	符号
S	19	6859	28	13492928512	19	S
U	21	9261	21	1801088541	21	U
Z	26	17576	20	1280000000	26	Z
A	01	1	1	1	01	A
N	14	2744	5	78125	14	N
N	14	2744	5	78125	14	N
E	05	125	26	8031810176	05	E
发送方的计算			接收方的计算			

其它公开密钥算法



- 背包算法 (Merkle and Hellman, 1978)

- 算法思想是，某人拥有大量的物品，每个物品的重量各不相同。为了编码一个消息，这个人秘密选择一组物品并将物品放在一个背包中。背包中物品的总重量公开，所有可能的物品也被公开列出，但是背包中物品的细则是保密的。“根据给定的总重量找出可能的物品明细列表”被认为是一个计算上不可行的问题

- El Gamal算法

- 建立在计算离散对数的困难度基础之上

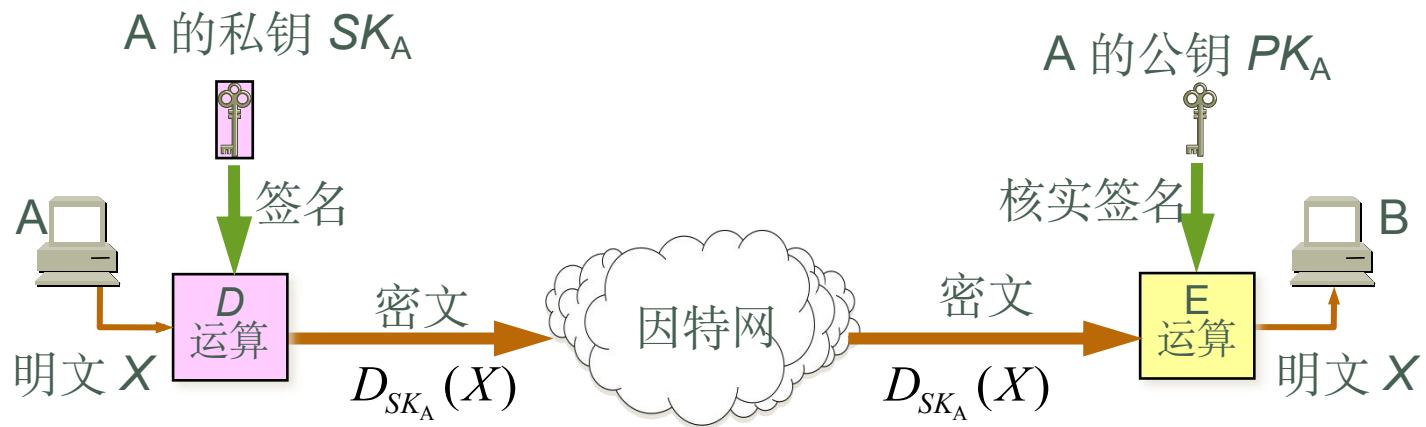
- 椭圆曲线算法

7.3 数字签名



- 数字签名必须保证以下三点：
 1. 报文鉴别——接收者能够核实发送者对报文的签名；
 2. 报文的完整性——发送者事后不能抵赖对报文的签名；
 3. 不可否认——接收者不能伪造对报文的签名。
- 现在已有多种实现各种数字签名的方法。但采用公钥算法更容易实现。

数字签名的实现

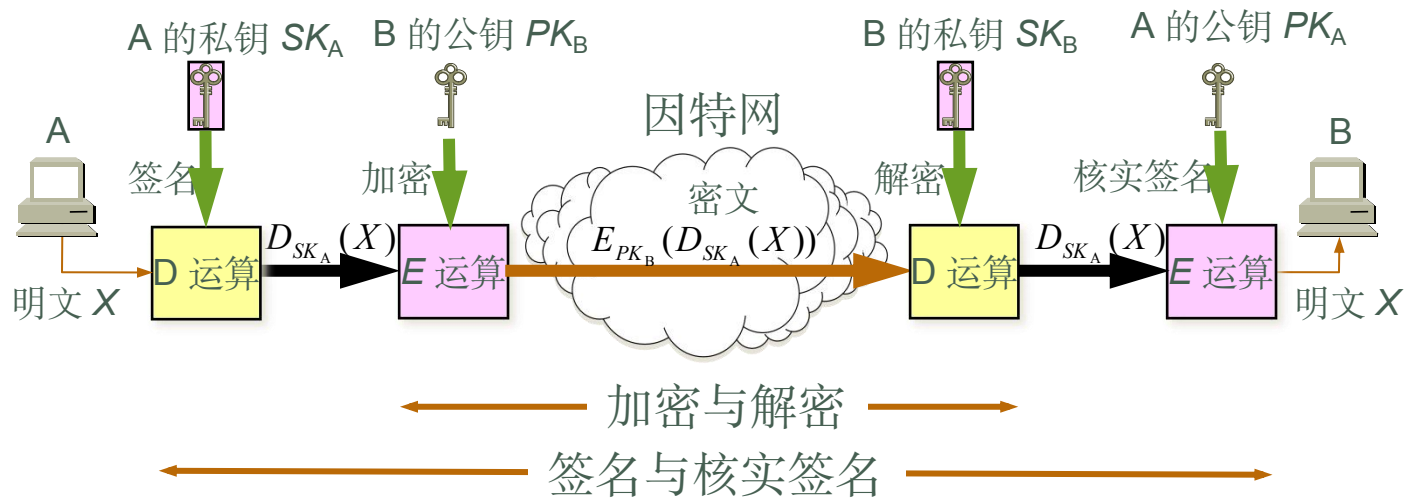


数字签名的实现



- 因为除 A 外没有别人能具有 A 的私钥，所以除 A 外没有别人能产生这个密文。因此 B 相信报文 X 是 A 签名发送的。
- 若 A 要抵赖曾发送报文给 B，B 可将明文和对应的密文出示给第三者。第三者很容易用 A 的公钥去证实 A 确实发送 X 给 B。
- 反之，若 B 将 X 伪造成 X' ，则 B 不能在第三者前出示对应的密文。这样就证明了 B 伪造了报文。

具有保密性的数字签名



7.4 鉴别



- 在信息的安全领域中，对付被动攻击的重要措施是加密，而对付主动攻击中的篡改和伪造则要用鉴别(authentication)。
- 报文鉴别使得通信的接收方能够验证所收到的报文（发送者和报文内容、发送时间、序列等）的真伪。
- 使用加密就可达到报文鉴别的目的。但在网络的应用中，许多报文并不需要加密。应当使接收者能用很简单的方法鉴别报文的真伪。

鉴别与授权不同



- 鉴别与授权(authorization)是不同的概念。
- 授权涉及到的问题是：所进行的过程是否被允许（如是否可以对某文件进行读或写）。

7.4.1 报文鉴别



- 许多报文并不需要加密但却需要数字签名，以便让报文的接收者能够鉴别报文的真伪。
- 然而对很长的报文进行数字签名会使计算机增加很大的负担（需要进行很长时间的运算。
- 当我们传送不需要加密的报文时，应当使接收者能用很简单的方法鉴别报文的真伪。

报文摘要 MD(Message Digest)



- A 将报文 X 经过报文摘要算法运算后得出很短的报文摘要 H 。然后然后用自己的私钥对 H 进行 D 运算，即进行数字签名。得出已签名的报文摘要 $D(H)$ 后，并将其追加在报文 X 后面发送给 B。
- B 收到报文后首先把已签名的 $D(H)$ 和报文 X 分离。然后再做两件事。
 - 用A的公钥对 $D(H)$ 进行 E 运算，得出报文摘要 H 。
 - 对报文 X 进行报文摘要运算，看是否能够得出同样的报文摘要 H 。如一样，就能以极高的概率断定收到的报文是 A 产生的。否则就不是。

报文摘要的优点



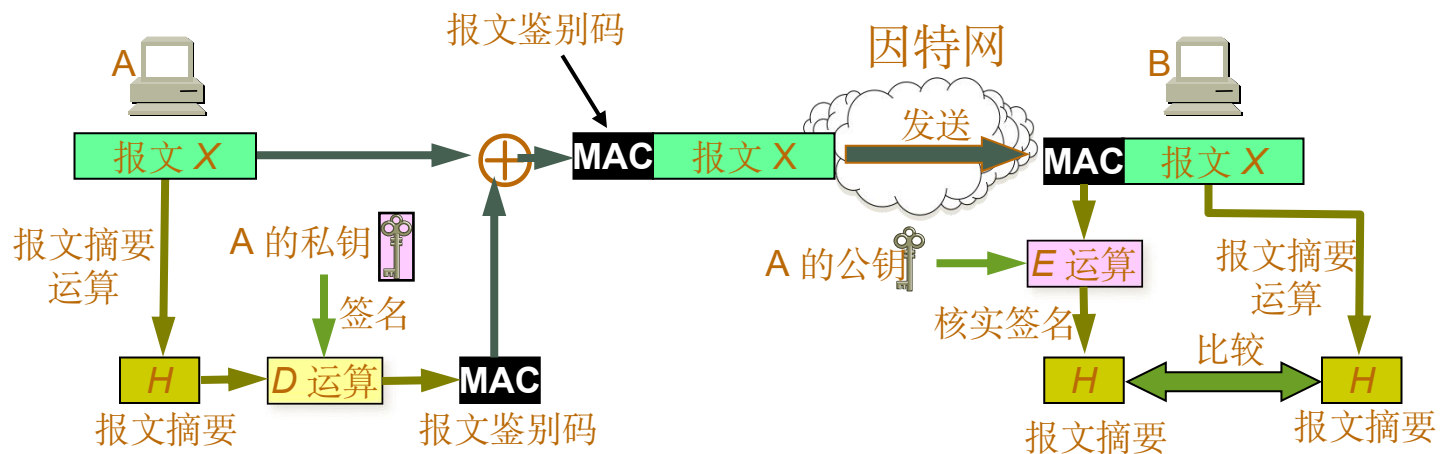
- 仅对短得多的定长报文摘要 H 进行数字签名要比对整个长报文进行数字签名要简单得多，所耗费的计算资源也小得多。
- 但对鉴别报文 X 来说，效果是一样的。也就是说，报文 X 和已签名的报文摘要 $D(H)$ 合在一起是**不可伪造的**，是**可检验的**和**不可否认的**。

报文摘要算法



- 报文摘要算法就是一种散列函数。这种散列函数也叫做密码编码的校验和。报文摘要算法是防止报文被人恶意篡改。
- 报文摘要算法是精心选择的一种单向函数。
- 可以很容易地计算出一个长报文 X 的报文摘要 H ，但要想从报文摘要 H 反过来找到原始的报文 X ，则实际上是不可能的。
- 若想找到任意两个报文，使得它们具有相同的报文摘要，那么实际上也是不可能的。

报文摘要的实现



7.4.2 实体鉴别

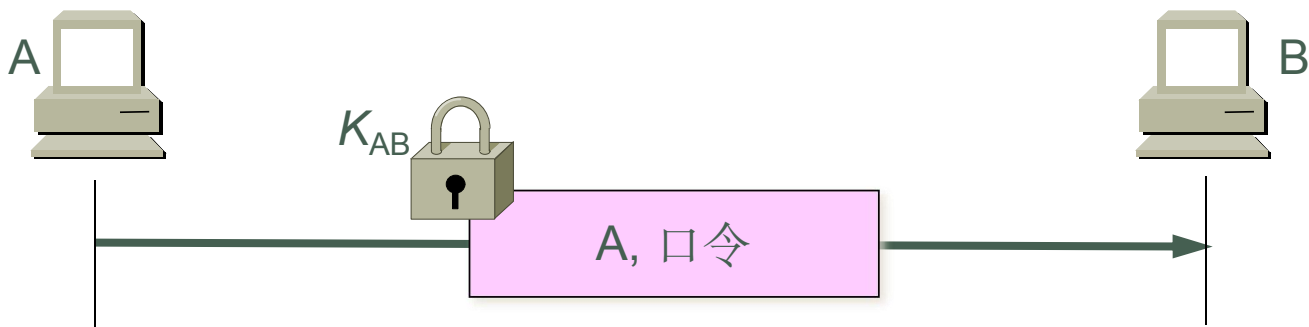


- 实体鉴别和报文鉴别不同。
- 报文鉴别是对每一个收到的报文都要鉴别报文的发送者，而实体鉴别是在系统接入的全部持续时间内对和自己通信的对方实体只需验证一次。

最简单的实体鉴别过程



- A 发送给 B 的报文的被加密，使用的是对称密钥 K_{AB} 。
- B 收到此报文后，用共享对称密钥 K_{AB} 进行解密，因而鉴别了实体 A 的身份。



明显的漏洞



- 入侵者 C 可以从网络上截获 A 发给 B 的报文。C 并不需要破译这个报文（因为这可能很花很多时间）而可以直接把这个由 A 加密的报文发送给 B，使 B 误认为 C 就是 A。然后 B 就向伪装是 A 的 C 发送应发给 A 的报文。
- 这就叫做**重放攻击**(replay attack)。C 甚至还可以截获 A 的 IP 地址，然后把 A 的 IP 地址冒充为自己的 IP 地址（这叫做 IP 欺骗），使 B 更容易受骗。

使用不重数



- 为了对付重放攻击，可以使用不重数(nonce)。不重数就是一个不重复使用的大随机数，即“一次一数”。

7.5 密钥分配



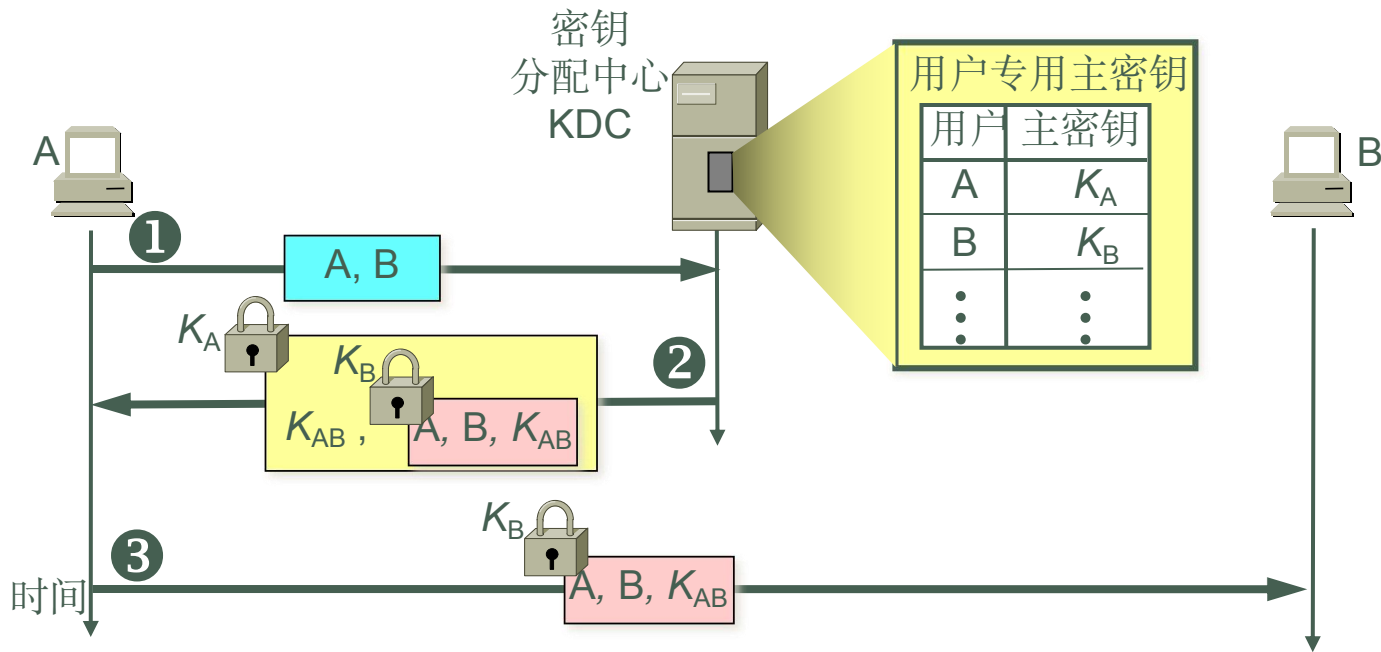
- 密钥管理包括：密钥的产生、分配、注入、验证和使用。本节只讨论密钥的分配。
- 密钥分配是密钥管理中最大的问题。密钥必须通过最安全的通路进行分配。
- 目前常用的密钥分配方式是设立**密钥分配中心** KDC (Key Distribution), 通过 KDC 来分配密钥。

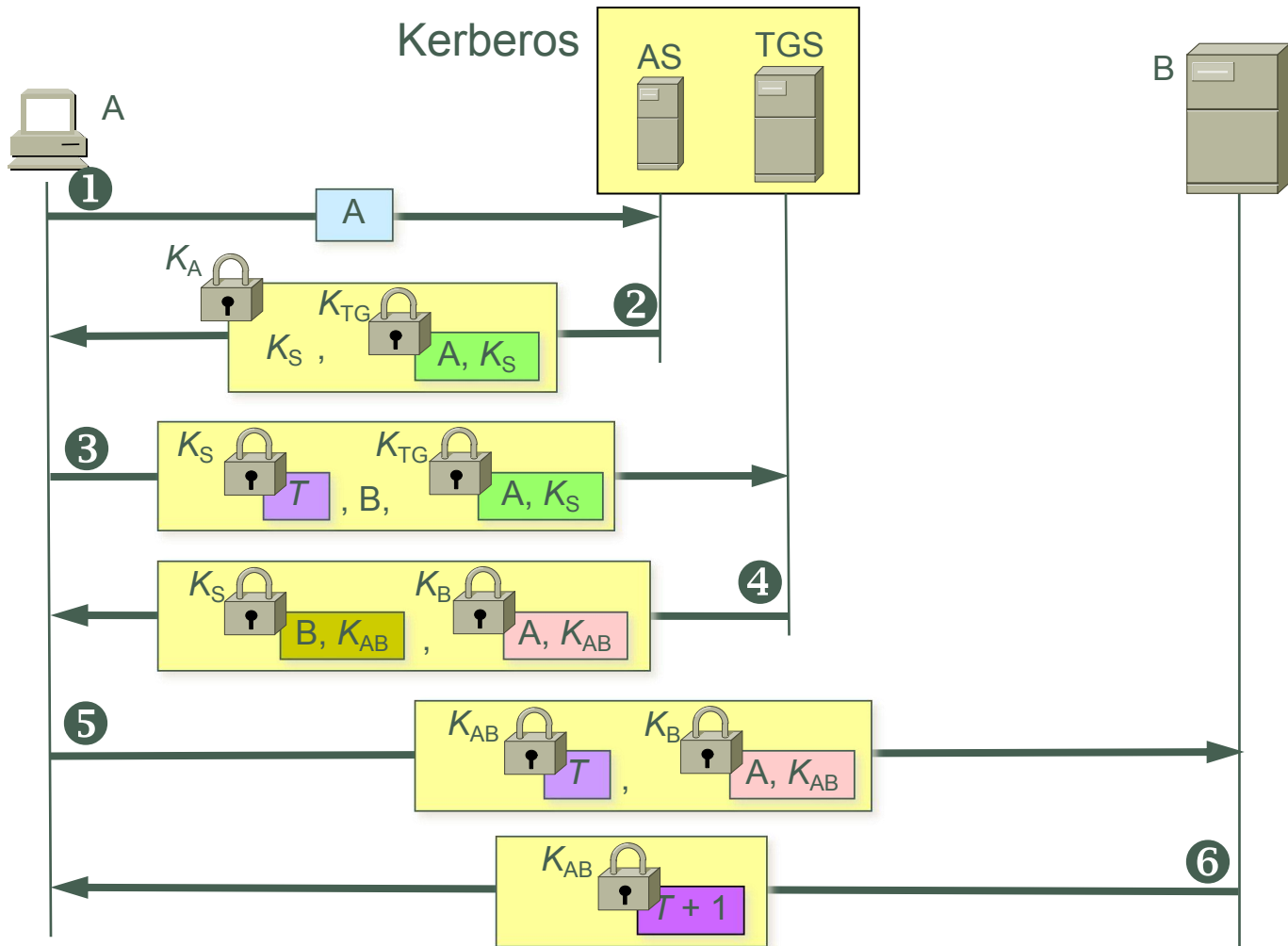


7.5.1 对称密钥的分配

- 目前常用的密钥分配方式是设立**密钥分配中心** KDC (Key Distribution Center)。
- KDC 是大家都信任的机构，其任务就是给需要进行秘密通信的用户临时分配一个会话密钥（仅使用一次）。
- 用户 A 和 B 都是 KDC 的登记用户，并已经在 KDC 的服务器上安装了各自和 KDC 进行通信的**主密钥**（master key） K_A 和 K_B 。“主密钥”可简称为“密钥”。

对称密钥的分配





7.5.2 公钥的分配



- 需要有一个值得信赖的机构——即**认证中心CA** (Certification Authority), 来将公钥与其对应的实体（人或机器）进行**绑定(binding)**。
- 认证中心一般由政府出资建立。每个实体都有CA 发来的**证书(certificate)**, 里面有公钥及其拥有者的标识信息。此证书被 CA 进行了数字签名。任何用户都可从可信的地方获得认证中心 CA 的公钥, 此公钥用来验证某个公钥是否为某个实体所拥有。有的大公司也提供认证中心服务。



7.6 因特网使用的安全协议

7.6.1 网络层安全协议

1. **IPsec** 协议

网络层保密是指所有在 **IP** 数据报中的数据都是加密的。

IPsec 中最主要的两个部分



- **鉴别首部 AH (Authentication Header):** AH鉴别源点和检查数据完整性，但不能保密。
- **封装安全有效载荷 ESP (Encapsulation Security Payload):** ESP比 AH 复杂得多，它鉴别源点、检查数据完整性和提供保密。

安全关联 SA(Security Association)



- 在使用 AH 或 ESP 之前，先要从源主机到目的主机建立一条网络层的逻辑连接。此逻辑连接叫做安全关联 SA。
- IPsec 就把传统的因特网无连接的网络层转换为具有逻辑连接的层。

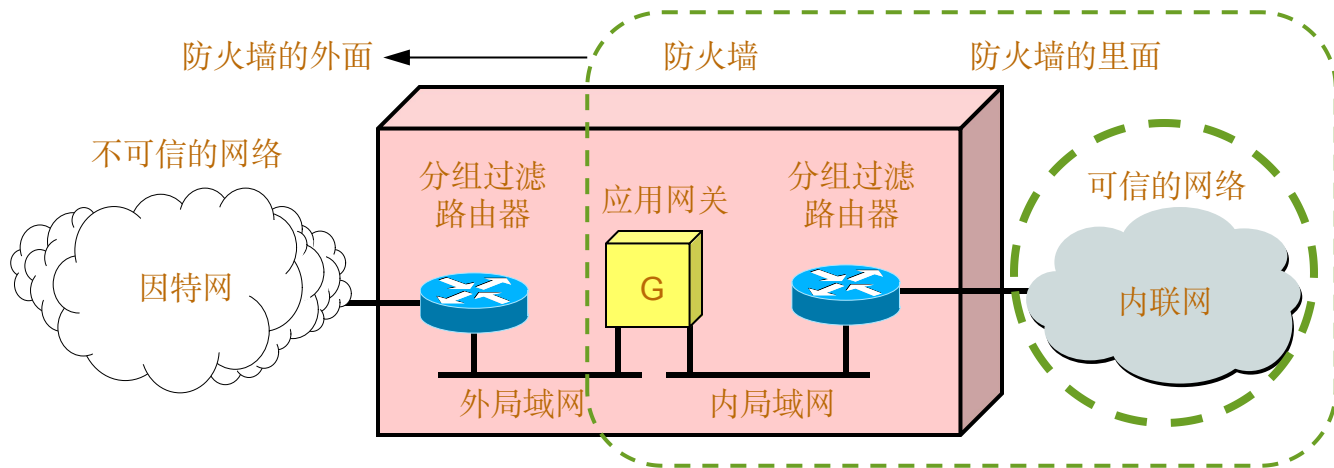
7.7 系统安全： 防火墙与入侵检测



7.7.1 防火墙

- **防火墙**是由软件、硬件构成的系统，是一种特殊编程的路由器，用来在两个网络之间实施接入控制策略。接入控制策略是由使用防火墙的单位自行制订的，为的是可以最适合本单位的需要。
- 防火墙内的网络称为“**可信的网络**” (trusted network)，而将外部的因特网称为“**不可信的网络**” (untrusted network)。
- 防火墙可用来解决内联网和外联网的安全问题。

防火墙在互连网络中的位置



防火墙的功能



- 防火墙的功能有两个：阻止和允许。
- “阻止”就是阻止某种类型的通信量通过防火墙（从外部网络到内部网络，或反过来）。
- “允许”的功能与“阻止”恰好相反。
- 防火墙必须能够识别通信量的各种类型。不过在大多数情况下防火墙的主要功能是“阻止”。

防火墙技术一般分为两类



- (1) 网络级防火墙——用来防止整个网络出现外来非法的入侵。属于这类的有分组过滤和授权服务器。前者检查所有流入本网络的信息，然后拒绝不符合事先制订好的一套准则的数据，而后者则是检查用户的登录是否合法。
- (2) 应用级防火墙——从应用程序来进行接入控制。通常使用应用网关或代理服务器来区分各种应用。例如，可以只允许通过访问万维网的应用，而阻止 FTP 应用的通过。

7.7.2 入侵检测系统



- 入侵检测系统 IDS (Intrusion Detection System)能够在入侵已经开始，但还没有造成危害或在造成更大危害前，及时检测到入侵，以便尽快阻止入侵，把危害降低到最小。
- 基于特征的 IDS 维护一个所有已知攻击标志性特征的数据库。
- 基于特征的IDS只能检测已知攻击，对于未知攻击则束手无策。

7.8 网络病毒与防治



- 导致计算机病毒产生的社会渊源
- 计算机病毒概述
- 计算机病毒的特征
- 计算机病毒传染方式
- 计算机病毒的分类

导致计算机病毒产生的社会渊源



- 计算机病毒是计算机技术和以计算机为核心的社会信息化进程发展到一定阶段的必然产物，是计算机犯罪的一种新的衍化形式
- 产生计算机病毒的原因，大致可以分为以下几种：
 - 计算机爱好者出于好奇或兴趣，也有的是为了满足自己的表现欲或制作恶作剧
 - 产生于个别人的报复、破坏心理
 - 来源于游戏软件
 - 来源于软件加密
 - 用于研究或实验而设计的“有用”的程序
 - 出于政治、经济和军事等特殊目的，一些组织或个人也会编写一些程序用于进攻对方的计算机

狭义定义



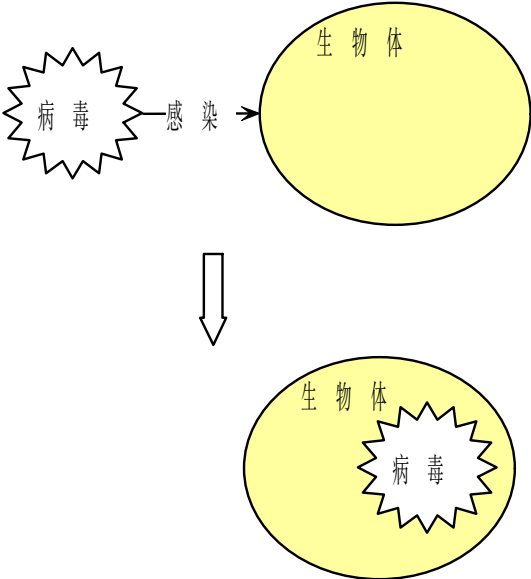
- 1994年2月18日，我国正式颁布实施了《中华人民共和国计算机信息系统安全保护条例》，在《条例》第二十八条中明确指出：“计算机病毒是指编制或者在计算机程序中插入的破坏计算机功能或者破坏数据，影响计算机使用并且能够自我复制的一组计算机指令或者程序代码”
- 这一定义，具有一定的法律性和权威性

广义定义

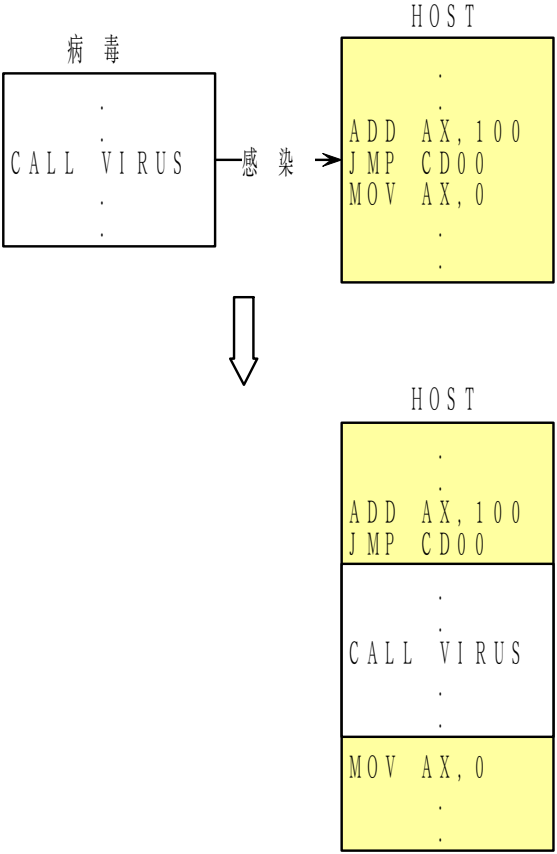


- 计算机病毒(Computer Virus), 是一种具有自我复制能力的计算机程序, 它不仅能破坏计算机系统, 而且还能传播、感染到其他的系统, 能影响计算机软件、硬件的正常运行, 破坏数据的正确与完整。
 - 类似于生物病毒, 它能把自身附着在各种类型的文件上或寄生在存储媒介中, 能对计算机系统和网络进行各种破坏;
 - 有独特的复制能力和传染性, 能够自我复制——主动传染, 另一方面, 当文件被复制或在网络中从一个用户传送到另一个用户时——被动传染, 它们就随同文件一起蔓延开来

病毒感染示意图



生物病毒感染与寄生



计算机病毒感染与寄生

计算机病毒的特征



根据对计算机病毒的产生、传染和破坏行为的分析，病毒有以下几个主要特点。

1. 传染性(基本特征)
2. 夺取系统控制权
3. 隐蔽性
4. 破坏性
5. 潜伏性
6. 可触发性
7. 不可预见性

计算机病毒传染方式



- 计算机不运行时不存在对磁盘的读写或数据共享；没有磁盘的读写，病毒不能传入磁性存储介质，而只能驻留于内存之中或驻留于存储设备之中。计算机运行就含有很频繁的磁盘读写工作，就容易得到病毒传染的先决条件。
- 有了条件病毒是如何传染的呢？
 1. **驻入内存：**病毒要达到传染的目的必须驻留于内存之中，所以病毒传染的第一步是驻留内存；
 2. **寻找传染机会：**病毒驻入内存之后，首先寻找可进行攻击的对象，并判定这一对象是否可被传染（有些病毒的传染是无条件的）；
 3. **进行传染：**当病毒寻找到传染的对象并判定可进行传染之后，通过**INT 13H**这一磁盘中断服务程序达到传染磁盘的目的，并将其写入磁盘系统；
- 一般病毒将在内存中申请一空间，以便常驻内存或为常驻内存程序（TSR），病毒为使自已不被发现，此时一般不覆盖其它数据的，通常病毒程序写给于内存高端，其传染方式如上病毒存储方式。

计算机病毒的分类



- 各种不同种类的病毒有着各自不同的特征，它们有的以感染文件为主、有的以感染系统引导区为主、大多数病毒只是开个小小的玩笑
- 少数病毒危害极大（如臭名昭著CIH病毒）

病毒、蠕虫和木马的区别



● 病毒的特点

计算机病毒是编写的一段程序，它可以在未经用户许可，甚至在用户不知情的情况下改变计算机的运行方式。病毒必须满足两个条件：

- 自行执行：它通常将自己的代码置于另一个程序的执行路径中。
- 自我复制：病毒代码的明确目的是自我复制。如：可以用受毒感染的文件副本替换其他可执行文件。

● 与蠕虫相比，病毒可破坏计算机硬件、软件和数据。

蠕虫的特点



- 蠕虫属于计算机病毒的子类，所以也称为“蠕虫病毒”。通常，蠕虫的传播无需人为干预，并可通过网络进行自我复制，在复制过程中可能有改动。与病毒相比，蠕虫可消耗内存或网络带宽，并导致计算机停止响应。
- 与病毒类似，蠕虫也在计算机与计算机之间自我复制，但蠕虫可自动完成复制过程，因为它接管了计算机中传输文件或信息的功能。

特洛伊木马



- 特洛伊木马(Trojan Horse), 简称木马, 是一种恶意程序, 是一种基于远程控制的黑客工具, 一旦侵入用户的计算机, 就悄悄地在宿主计算机上运行, 在用户毫无察觉的情况下, 让攻击者获得远程访问和控制系统的权限, 进而在用户的计算机中修改文件、修改注册表、控制鼠标、监视/控制键盘, 或窃取用户信息
- 古希腊特洛伊之战中利用木马攻陷特洛伊城; 现代网络攻击者利用木马, 采用伪装、欺骗(哄骗, Spoofing)等手段进入被攻击的计算机系统中, 窃取信息, 实施远程监控

木马的特点



- 木马(trojan)与病毒的主要区别是木马并不像病毒那样复制自身
- 木马的特点：
 - 不感染其他的文件
 - 不破坏计算机系统
 - 不进行自我复制
- 木马的主要作用：作为远程控制、窃取密码的工具，它是一个具有内外连接功能的后门程序。
- 木马的两种主要传播途径：电子邮件和文件下载。

木马的组成

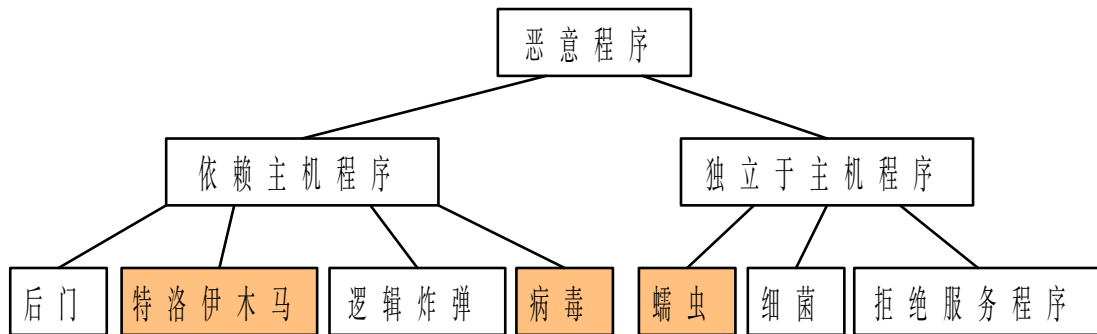


- 一般的木马程序包括客户端和服务端两个程序，其中：
 - 客户端：用于攻击者远程控制植入木马的计算机（即服务器端）
 - 服务器端：是植入木马程序的远程计算机。
- 当木马程序或带有木马的其他程序执行后，木马首先会在系统中潜伏下来，并修改系统的配置参数，每次启动系统时都能够实现木马程序的自动加载。

恶意程序



- 未经授权便干扰或破坏计算机系统/网络的程序或代码称之为恶意程序/恶意代码
- 恶意程序大致可以分为两类：
 - 依赖于主机程序的恶意程序
 - ◆ 不能独立于应用程序或系统程序，即存在宿主
 - 独立于主机程序的恶意程序
 - ◆ 能在操作系统上运行的、独立的程序



本章小结



- 数据加密模型
- 对称密钥密码体制和公钥密码体制
- 鉴别与数字签名
- 通信安全机制
- 计算机网络病毒

END!